THE SHARED SIGNALS FRAMEWORK (SSF)

So far, this chapter has focused on signals moving within a single organization. But authorization increasingly relies on signals that cross organizational boundaries: login risk from an identity provider, device posture from a third-party endpoint service, or session information shared between SaaS partners.

The Shared Signals Framework (SSF) (https://openid.net/wg/sharedsignals/), created by the OpenID Foundation, defines a standard method for organizations to exchange updates securely. SSF does not specify what the signals contain; instead, it provides a protocol for securely transmitting and receiving them. Each message is signed to verify integrity and includes metadata that identifies the issuer, timestamp, and event type to establish provenance.

SSF utilizes common web technologies—HTTPS, JSON message bodies, and JWT signatures—and is intended for event-driven communication. Instead of polling for updates, relying systems subscribe to notifications such as user session revoked, device posture changed, or risk level elevated.

At ACME, the Customer Collaboration platform is testing SSF to get risk updates from external SaaS partners. When a partner system reports suspicious activity on a shared account, ACME's PIP ingests the signed SSF message and updates the local context. The PDP can then re-evaluate access in near real time, reducing the window of exposure.

SSF's value is in offering confidence and consistency for inter-domain signaling. It guarantees that signals are genuine, traceable, and confidential.

12.6 Authorization context normalization

By this point, ACME had built several working authorization systems. Each had its own custom design. The Customer Collaboration platform, the